

Shyware SDK Compliance Guide

Effective date: upon publication at <https://shyware.fyi/legal/compliance/>

Purpose

This guide describes how Shyware SDK is intended to support SaaS customers that act as controllers for their own users' personal data. It is written for privacy, security, procurement, and engineering teams reviewing Shyware as an embedded analytics and reconciliation SDK.

Shyware provides processor services to the customer. The customer determines whether, why, and how Shyware is used in the customer's product. Shyware processes customer user data only to provide, secure, maintain, and support the SDK and related hosted services, and only under the customer's documented instructions.

Role Allocation

Party	Role	Responsibilities
Customer	Controller	Determines the purposes and means of processing, provides notices, identifies legal basis, handles user relationship, configures retention, responds to data subject requests, and approves subprocessors.
Shyware	Processor	Processes customer user data on behalf of the customer, implements processor security measures, supports data subject request workflows, maintains subprocessors, and assists with DPIA/security review.
Subprocessors	Subprocessors	Provide infrastructure, storage, identity verification, security, support, or operational services under written terms imposing data protection obligations.

Processing Overview

Shyware is designed around structural separation between behavioral payload records and identity records. The Mainhub patent-backed posture is specifically a canonical-state posture: accepted canonical state should not contain or compute a participant-specific identity–payload join under valid state transitions. It is not a representation that all off-chain, endpoint, network, IDV, wallet, or controller systems are anonymous. In the recommended deployment:

Processing Area	Description
SDK event capture	The SDK captures customer-configured product events from the customer’s application.
Payload sealing	Behavioral payloads are sealed before commitment using customer-configured or Shyware-managed cryptographic controls.
Canonical state	Canonical state stores structurally disjoint records and should not represent or compute a direct identity-behavior join under valid state transitions.
Reconciliation path	User-authenticated recovery, access, portability, or deletion operations use a separate reconciling path governed by customer configuration and authorization policy; this path is outside the canonical-state guarantee and must be separately controlled.
Audit and attestation	Period-close counts, Merkle roots, signatures, and audit records can support compliance review without exposing user-level behavioral joins in canonical state.

Customer Responsibilities

Customers should complete the following before production use:

Area	Customer Action
Legal basis	Identify the Article 6 GDPR legal basis or other applicable lawful basis for the customer’s use case.

Area	Customer Action
Privacy notice	Disclose the categories of events collected, the purposes of processing, Shyware's role as processor, retention periods, user rights, and any international transfer mechanism.
Configuration	Configure only the event fields necessary for the customer's stated purposes. Avoid sending raw sensitive data, payment credentials, government identifiers, passwords, authentication secrets, or special-category data unless Shyware has expressly agreed in writing.
Data minimization	Use stable opaque identifiers and avoid payload fields that directly identify a user unless required for the customer's purpose.
Retention	Configure retention and deletion behavior consistent with the customer's legal basis and user-facing commitments.
Data subject requests	Maintain the user-facing intake process and route Shyware-assisted retrieval, portability, erasure, restriction, or objection workflows through authorized customer administrators.
DPIA	Conduct a DPIA when required by law or when the customer's use involves large-scale behavioral analytics, systematic monitoring, vulnerable users, sensitive contexts, or innovative technology.
Vendor review	Review the Shyware DPA, subprocessors, security measures, and technical documentation before production use.

Records of Processing Generator

The Shyware SDK includes an Art. 30 Records of Processing generator that pre-fills all fields derivable from the deployment shyconfig manifest.

Usage:

```
node scripts/generate-rop.mjs --config shyconfig.json --format md
```

The generator outputs a structured document with:

- Art. 30(1)(b) purposes — derived from `contract_version`

- Art. 30(1)(c) data subjects and categories — derived from `contract_version`
- Art. 30(1)(d) recipients — derived from authority model and subprocessors
- Art. 30(1)(f) retention — populated from `shyconfig.retention` block if present; otherwise flagged `REQUIRED_OPERATOR_INPUT`
- Art. 30(1)(g) security measures — derived from `signing.backend` and `deployment.default_posture`
- Subprocessor list — derived from `identity.provider` and `wire.provider`
- Authority model — derived from `contract_version` (3-party sealer-governed or 4-party count-match)

Fields requiring operator input are marked `REQUIRED_OPERATOR_INPUT`. The operator must complete these fields, in particular: controller name and contact, DPO contact, Art. 6 legal basis per jurisdiction, specific retention periods and deletion cron schedule, and sub-processor DPA status.

Retention configuration: Add a `retention` block to `shyconfig.json`:

```
"retention": {
  "canonical_records_days": 2555,
  "off_chain_linkage_days": 730,
  "deletion_cron": "0 2 * * *",
  "basis": "financial records - 7 years per local law"
}
```

Once configured, the deletion cron schedule must be operationally enforced — this is a governance obligation that is not verifiable by unit assertions alone, but the presence of the schedule in the `shyconfig` is verified by the RoP generator test suite (92/92 assertions pass).

Data Categories

Shyware should be configured to process only the data needed for the customer’s product analytics, reconciliation, security, and audit purposes.

Category	Examples	Default Position
End user identifiers	Opaque user ID, account ID, pseudonymous identity hash, session identifier	Permitted when needed for reconciliation or service integrity.
Product event data	Page, action, feature, timestamp, device/browser metadata, tenant context	Permitted when configured by the customer.

Category	Examples	Default Position
Security and integrity data	Attestation status, replay-prevention values, signature metadata, audit counters	Permitted for security and compliance.
Support data	Customer administrator contact details, support tickets, configuration metadata	Permitted for account support and service operation.
Sensitive data	Special-category data, precise biometric templates, payment card data, government IDs, passwords, secrets	Not permitted unless expressly agreed in a signed addendum.

Data Subject Rights

The customer remains responsible for receiving and evaluating data subject requests. Shyware assists the customer by providing available technical workflows for:

Right	Shyware Support
Access	Retrieve available customer user records through authorized customer workflows.
Portability	Export available user-associated data in a structured format when enabled for the deployment.
Erase	Delete or render unavailable applicable records according to the customer's instruction and configured retention controls.
Restriction or objection	Suspend, suppress, or stop future processing for an identified user when supported by the integration.
Rectification	Correct customer-controlled user attributes by processing corrected inputs or deleting and replacing affected records where technically appropriate.

Security Measures

Shyware's baseline processor security program includes:

Control	Baseline Measure
Encryption in transit	TLS for data transport.
Encryption at rest	Encryption for hosted storage and backups where applicable.
Access control	Role-based access for Shyware personnel and administrative systems.
Confidentiality	Personnel and contractor confidentiality obligations.
Logging	Operational and security logging for hosted service components.
Key management	Managed key custody, rotation, and separation practices appropriate to the deployment.
Change control	Controlled release process for SDK and hosted service changes.
Vulnerability management	Dependency review, patching, and remediation workflow.
Incident response	Security incident intake, investigation, containment, remediation, and customer notification workflow.

Subprocessors

Shyware may use subprocessors for hosting, storage, identity verification, monitoring, security, support, and business operations. Shyware will maintain a subprocessor list at or linked from <https://shyware.fyi/legal/compliance/>. Customers may object to new subprocessors as described in the Data Processing Agreement.

International Transfers

Where Shyware transfers personal data from the EEA, UK, or Switzerland to a third country, Shyware will use an appropriate transfer mechanism, such as standard contractual clauses, the UK international data transfer addendum, an adequacy decision, or another lawful transfer mechanism available for the relevant jurisdiction.

Customer Privacy Notice Language

Customers can adapt the following language for their own privacy notice:

We use Shyware to provide privacy-preserving analytics, reconciliation, security, and audit functionality in our service. Shyware acts as our processor and processes data only on our instructions. Shyware is designed to reduce direct linkage between user identity records and behavioral event records in its canonical processing architecture.

Any recovery, reconciliation, identity-verification, device, wallet, or customer-support workflow may involve separate personal data processing that we configure and govern as controller. We remain responsible for the purposes of processing, user notices, legal basis, retention choices, and responses to privacy rights requests.

Production Readiness Checklist

Item	Owner
DPA accepted and linked from the legal terms	Legal
Privacy notice updated	Legal
Data map completed	Privacy / Engineering
Event schema reviewed for minimization	Engineering
Retention configured	Engineering / Legal
Subprocessor list reviewed	Procurement / Legal
DPIA completed where required	Privacy
Security review completed	Security
Data subject request workflow tested	Support / Engineering
Incident contacts configured	Security / Legal

Contract Variant Coverage — All Embodiments

The following table enumerates all 13 shyware contract variants, their authority model, the primary applicable regulation, and the DPIA source file. Every variant has a corresponding DPIA source file in `patent/mainhub/dpia/source/` and has been verified by the three-stack test suite (run 26369476939).

Domain	Contract	Authority model	Primary regulation	DPIA source
Civic voting + hostile-regime	shyvoting-v1	4-party count-match	GDPR; jurisdiction-specific election law	DPIA_CIVIC_VOTING_REFERENDA.t
Private value transfer	shywire-v1	4-party count-match	GDPR; BSA (5-yr retention); AML/OFAC	DPIA_PRIVATE_VALUE_TRANSFER.t
Private chat / dispatch	shychat-v1	3-party sealer-governed	GDPR; ePrivacy Directive	DPIA_PRIVATE_CHAT_SCYTALE_COM
Browser analytics	shybrowser-v1	3-party sealer-governed	GDPR; ePrivacy; CCPA	DPIA_BROWSER_ANALYTICS.tex

Domain	Contract	Authority model	Primary regulation	DPIA source
Commodity custody	shycustody-v1	4-party count-match	GDPR; commodity trading regs	DPIA_COMMODITY_CUSTODY_VAULTS.tex
DAO governance	shyshares-v1	4-party count-match	GDPR; securities law (jurisdiction-specific)	DPIA_DAO_WALLET_GOVERNANCE.tex
Revenue financing	shycontracts-v1	4-party count-match	GDPR; consumer credit (jurisdiction-specific)	DPIA_REVENUE_FINANCING_CONTRACTS.tex
Health record vault (EHR)	shystore-v1	3-party sealer-governed	GDPR Art. 9; HIPAA 45 CFR §164.312; HITECH	DPIA_HEALTH_RECORD_VAULT.tex
Credential vault / authenticator	shystore-v1	3-party sealer-governed	GDPR; NIST SP 800-63B (IAL2/AAL2)	DPIA_CREDENTIAL_VAULT_AUTHENTICATOR.tex
Anonymous betting	shybets-v1	4-party count-match	GDPR; gambling regulation (jurisdiction-specific)	DPIA_BETTING_MARKETS.tex
Informant stream	shyrest-v1	4-party count-match	GDPR; whistleblower protection (EU Directive 2019/1937)	DPIA_INFORMANT_STREAM_ANONYMOUS.tex
Sealed-bid auction	shylots-v1	4-party count-match	GDPR; auction / commodity regulation	DPIA_SEALED_BID_AUCTION_LOTS.tex
Private video streaming	shystream-v1	3-party sealer-governed	GDPR; ePrivacy; DMCA	DPIA_PRIVATE_STREAMING.tex

HIPAA Compliance Posture

For US deployments involving Protected Health Information (PHI) of US persons, HIPAA applies independently of GDPR. This section applies to all shyware-v1 deployments where the operator is a covered entity or business associate under HIPAA (45 CFR §160.103).

Structural Basis for HIPAA Compliance

Shyware is not a public blockchain. It is a permissioned BFT ABCI state machine operated by known parties who can execute Business Associate Agreements (BAAs). This is the critical architectural distinction that enables HIPAA compliance: public blockchain networks cannot be party to a BAA; the Shyware operator can and must be.

Actual PHI lives in operator-controlled CockroachDB (off-chain, BAA-eligible). The canonical ledger stores only sealed payload commitments (hashes) — not plaintext PHI. This is the hybrid architecture recommended by HHS Office for Civil Rights: off-chain PHI in a compliant store, on-chain integrity proof. The structural two-list invariant ensures even the hybrid architecture preserves minimum-necessary: no join between the PHI payload and the patient identity is ever materialised in canonical state.

BAA Template

A HIPAA Business Associate Agreement template for shyware-v1 deployments is provided in `HIPAA_BUSINESS_ASSOCIATE_AGREEMENT.tex` and published at <https://shyware.fyi/legal/privacy/dpia/dpaa>. The Operator executes this agreement with each Covered Entity customer. Shyware (Licensor) is not a party; Shyware warrants the structural guarantees that the Operator relies on to satisfy its Business Associate technical safeguard obligations.

Required BAAs Before Any PHI Flows

Sub-processor	Role	BAA available
AWS (KMS, EC2, S3 Object Lock)	Business Associate (compute + key mgmt)	Standard A
CockroachDB (HIPAA-eligible tier)	Business Associate (off-chain PHI storage)	CockroachD
Didit (if biometric fallback enabled)	Business Associate (identity context only; no PHI payload)	BAA requir
EHR provider (e.g. Epic)	Covered Entity / data source	Epic standa

2025/2026 HIPAA Security Rule NPRM

The HHS proposed rule (NPRM published 2025-01-06; final rule expected 2026) eliminates the addressable/required distinction in 45 CFR §164.312, making all technical safeguards mandatory. The shyware structural layer satisfies all proposed mandatory specifications. Operators must additionally implement: 72-hour breach notification to HHS, annual technology asset inventory, vulnerability scanning every 6 months, and network segmentation — these are operational obligations outside the shyware SDK.

Relationship to Other Legal Terms

This guide is explanatory and operational. The Data Processing Agreement, Terms of Service, Privacy Policy, and any signed order form or master services agreement control the legal relationship between Shyware and the customer.